Fiche de défense : Argent Intelligent

Secure Horizons, track 1 « Fintech Security: Guardians of Value ». État du dépôt au 11 octobre 2026. Chaque chiffre renvoie au fichier qui le porte ; ce qui n'existe pas est écrit comme tel.

Scénario de menace

Un agent IA à faible privilège lit une facture piégée. Une instruction glissée dans le document ordonne un paiement vers un bénéficiaire que l'attaquant contrôle. Sans contrôle entre celui qui lit et celui qui paie, l'agent financier exécute. Quatre variantes sont jouées : document piégé détecté, même attaque reformulée sous le seuil du détecteur, demande signée rejouée, facture déjà payée représentée. Nous n'empêchons pas l'injection, nous en bornons les conséquences : l'agent ne transmet que des identifiants, le montant et le bénéficiaire sont ceux inscrits au contrat.

Fonctions NIST CSF 2.0 couvertes

Fonction	Ce que fait le projet	Où
Govern (`GV.RR`)	Cinq rôles séparés sur le coffre : propriétaire, admission, relais, approbateur, gardien. Aucune action automatique ne déplace de fonds	`src/ArgentVault.sol`, `playbook.md`
Identify (`ID.AM`)	Registre des agents et de leur mandat sur la chaîne, doublé d'un jeton court par agent à la porte d'entrée	`src/ArgentVault.sol`, `gateway/src/tokens.ts`
Protect (`PR.AA`, `PR.DS`)	Liste d'émetteurs admis du L1 : le nœud refuse tout autre émetteur. Signature EIP-712 liée à la chaîne et au coffre, demande consommée une seule fois, validation humaine au-dessus du seuil	`infra/l1/`, `docs-jury/preuves/scene-aws.md`
Detect (`DE.CM`, `DE.AE`)	Détecteur à règles sur chaque demande (score, codes raison). Décision 0 du contrat lue dans l'événement `Decision`. Comité de trois vérificateurs LLM, non relié au coffre	`gateway/src/detector.ts`, `docs-jury/verificateurs-llm.md`
Respond (`RS.MA`, `RS.MI`, `RS.CO`)	Quarantaine, pause de l'agent, alerte, rapport d'incident prérempli, journal chaîné vérifiable par script	`response/src/engine.ts`, `playbook.md`
Recover (`RC.RP`)	Partiel : une pause ne se lève que par une décision humaine journalisée. Aucun plan de reprise au-delà	`response/`

Techniques et risques visés

Référentiel	Éléments visés
MITRE ATLAS	AML.T0051 LLM Prompt Injection : .001 Indirect (la facture piégée), .000 Direct. AML.T0053 AI Agent Tool Invocation
MITRE ATT&CK	T1657 Financial Theft, T1565.001 Stored Data Manipulation, T1684.001 Social Engineering: Impersonation
OWASP LLM 2025	LLM01 Prompt Injection, LLM06 Excessive Agency, LLM05 Improper Output Handling
OWASP Agentic 2026	ASI01 Agent Goal Hijack, ASI02 Tool Misuse, ASI03 Identity & Privilege Abuse, ASI07 Insecure Inter-Agent Communication, ASI09 Human-Agent Trust Exploitation
OWASP Smart Contract 2026	SC01 Access Control, SC02 Business Logic, SC05 Lack of Input Validation, SC06 Unchecked External Calls, SC08 Reentrancy : revue interne, `docs-jury/rapport-securite.md`

Métriques atteintes

Métrique	Valeur	Conditions et source
Taux de détection de la porte d'entrée	50 sur 100 (50 %)	Jeu de test synthétique, 100 attaques, détecteur `regles-0.3`, seuil 70. `docs/mesures/bench-test.json`
Faux positifs	4 sur 100 (4 %)	100 demandes légitimes du même jeu
Attaques passées la porte puis refusées par le contrat	2 sur 4 jouées	Scènes scriptées, sur notre L1 de test (`docs-jury/preuves/vault-l1-aws.md`) et sur anvil (`docs/mesures/demo.json`)
Attaques ayant abouti à une sortie de fonds	0 sur 4 jouées	Mêmes scènes. Ne vaut pas pour le jeu de test
Délai de détection	Porte : 226 ms après l'arrivée. Contrat : 1,9 s, jusqu'au bloc de décision	Un incident par chemin (scènes 3 et 4 sur le L1), lu dans les rapports d'incident
Délai de réponse	Porte : pause 24 ms, alerte 32 ms après la détection. Contrat : pause et alerte 6,5 s après le bloc	Mêmes incidents. Le chemin du contrat inclut l'attente de l'indexeur
Temps de calcul du détecteur	0,38 ms en moyenne, 25,573 ms au maximum	Règles seules, hors porte d'entrée
Comité LLM face à l'injection	12 votes sur 12 à 0 (refus), sur 4 injections	3 jouées en local, 1 sur le L1. `docs-jury/preuves/llm-injection-chain.md`
Tests	332 Foundry, 199 hors chaîne, tous verts	`docs-jury/tests.md`

Limites connues

- Données synthétiques, écrites par un modèle, une attaque pour une légitime. En production les attaques sont rares : avec 4 % de faux positifs, la majorité des blocages toucheraient des demandes légitimes.
- La porte manque une attaque sur deux du jeu de test. Combien le contrat en arrête sur ce jeu n'est pas mesuré : quatre scènes seulement.
- Le contrat ne vérifie pas la vérité d'une facture : une fausse dette inscrite par le rôle d'admission serait payée. Un propriétaire ou un administrateur du L1 compromis sort du modèle.
- La pause d'un agent est appliquée hors chaîne, par la porte et par le relais. Le contrat sait la poser (`pauseAgent`), aucun service ne l'appelle.
- L'alerte est affichée et journalisée, elle n'est envoyée à personne. La décision humaine est déclarée, pas authentifiée.
- Le verdict du marché de vérification n'entre pas dans la décision du coffre : jonction conçue, non construite.
- L1 de test à un seul validateur, fonds de test sans valeur, revue de sécurité interne sans audit indépendant.
- Délais mesurés sur un seul incident par chemin. La référence « règles fixes » n'est pas mesurée.